

High

High

Malicious

بريد إلكتروني احتيالي (phishing) يدّعي أنه من PayPal، يحاول خداع المستلم للنقر على رابط ضار بحجة تعليق الحساب. يحتوي على عدة مؤشرات احتيال واضحة تشمل نطاق مزيف، رابط ضار، وأسلوب هندسة اجتماعية يعتمد على الإلحاح والتخويف.

الأدلة المؤكدة

نطاق المرسل المزيف

عنوان المرسل: IT-Support@paypal-secure.com — النطاق paypal-secure.com ليس النطاق الرسمي لـ PayPal (paypal.com)

عنوان الرد المزيف

Reply-To: security-alert@paypal-secure.com — يستخدم نفس النطاق المزيف

موضوع يحتوي على إلحاح وتهديد

Subject: URGENT: Your account has been suspended — Action required within 24 hours

رابط تصيد احتيالي

الرابط المضمن في الزر: <http://paypal-secure-verification.com/login?user=ahmed.k&token=8f3a2b1c> — نطاق مختلف تماماً عن PayPal الرسمي، يحتوي على معاملات مشبوهة (token و user)

أسلوب هندسة اجتماعية

النص يستخدم التخويف ('unusual activity', 'temporarily suspended', 'permanent account closure') لدفع المستلم للتصرف بسرعة دون تفكير

تهديد بإغلاق الحساب

النص يهدد بإغلاق الحساب نهائياً وفقدان المعاملات المعقدة خلال 24 ساعة

الأحداث المشبوهة

محاولة تصيد احتيالي (phishing) تستهدف بيانات اعتماد PayPal

بريد إلكتروني يتظاهر بأنه من PayPal، يطلب من المستلم النقر على رابط للتحقق من الحساب. الرابط يوجه إلى نطاق مزيف مصمم لسرقة بيانات الاعتماد.

مؤشرات الاختراق (IOCs)

النوع	القيمة	السياق
domain	paypal-secure.com	نطاق مزيف يحاكي مستخدم في PayPal، عنوان المرسل
domain	paypal-secure-verification.com	نطاق تصيد احتيالي مستخدم في الرابط الضار
email	IT-Support@paypal-secure.com	عنوان المرسل المزيف
email	security-alert@paypal-secure.com	عنوان الرد المزيف
url	http://paypal-secure- verification.com/login? user=ahmed.k&token=8f3a2b1c	رابط تصيد احتيالي يستهدف سرقة بيانات الاعتماد

الجدول الزمني

09:14:00 2026-08-27

استلام البريد الاحتيالي من IT-Support@paypal-secure.com



الفرضيات

المهاجم يستخدم حملة تصيد واسعة تستهدف مستخدمي PayPal

البحث عن رسائل مشابهة وصلت لمستخدمين آخرين في نفس الفترة الزمنية

الموقع paypal-secure-verification.com يستضيف صفحة تصيد تحاكي صفحة تسجيل دخول PayPal

فحص الموقع بأدوات sandbox أو threat intelligence (لا يُنصح بزيارته مباشرة)

المهاجم قد يكون جمع عناوين بريد إلكتروني من تسريب بيانات سابق

التحقق من وجود عنوان ahmed.k@example.com في تسريبات بيانات معروفة

الثغرات في الأدلة

رؤوس البريد الكاملة (email headers) غير متوفرة — لا يمكن التحقق من SPF/DKIM/DMARC أو تتبع مسار البريد الفعلي

لا توجد معلومات عن عنوان IP المرسل الحقيقي

لا توجد معلومات عن محتوى صفحة التصيد الفعلية على paypal-secure-verification.com

لا توجد معلومات عن عدد المستخدمين الآخرين الذين استلموا نفس الرسالة

خطوات التحقيق التالية

عدم النقر على الرابط أو التفاعل مع البريد بأي شكل
حذف البريد فوراً من صندوق الوارد
الإبلاغ عن البريد ك phishing/spam لمزود البريد الإلكتروني
إعادة توجيه البريد إلى phishing@paypal.com (عنوان الإبلاغ الرسمي لـ PayPal)
التحقق من حساب PayPal الحقيقي عبر تسجيل الدخول المباشر من المتصفح (كتابة paypal.com يدوياً) وليس من خلال أي رابط
فحص النطاقات paypal-secure.com و paypal-secure-verification.com في قواعد threat intelligence
حظر النطاقات المذكورة في بوابة البريد الإلكتروني أو جدار الحماية إن أمكن
نشر تنبيه توعوي للمستخدمين الآخرين حول هذه الحملة الاحتيالية
البحث في سجلات البريد الإلكتروني عن رسائل أخرى من نفس النطاقات أو تحتوي على نفس الروابط

التوصيات الدفاعية

لا تنقر على الرابط ولا تدخل أي بيانات — البريد احتيالي بشكل قاطع
احذف البريد فوراً
أبلغ عن البريد لمزود البريد الإلكتروني ولـ PayPal الرسمي (phishing@paypal.com)
تحقق من حساب PayPal الحقيقي بتسجيل الدخول مباشرة عبر paypal.com (اكتب العنوان يدوياً)
فعل المصادقة الثنائية (2FA) على حساب PayPal إن لم تكن مفعلة
راجع نشاط الحساب للتأكد من عدم وجود معاملات غير مصرح بها
احظر النطاقات paypal-secure.com و paypal-secure-verification.com في أنظمة الحماية
وعّي المستخدمين الآخرين بهذا النوع من الهجمات وكيفية التعرف عليها
تذكر: PayPal الحقيقي لن يطلب منك أبداً النقر على رابط للتحقق من حسابك عبر البريد الإلكتروني

ملاحظات المحلل

هذا مثال كلاسيكي على هجومات تصيد احتيالي (phishing) يستهدف مستخدمي PayPal. المؤشرات واضحة جداً: نطاق مزيف، رابط ضار، أسلوب هندسة اجتماعية يعتمد على الإلحاح والتخويف. يجب على المحلل L1 أن يتعلم التعرف على هذه المؤشرات: فحص النطاق بعناية، عدم الثقة بالروابط المضمنة، والتحقق دائماً من الحسابات الحقيقية عبر تسجيل الدخول المباشر وليس من خلال روابط البريد الإلكتروني.

